

AUDIT REPORT

Code Quality Report

Tick & Taka — Bun monorepo (API, Android app, shared package)

Project	Tick & Taka (tick-taka)
Date	2026-10-06
Commit	3b5438b (branch main)
Auditor role	Staff Engineer (architecture, maintainability, security, performance)
Companion reports	QA_Report.pdf, UX_Report.pdf (separate auditors)
Mode	Read-only. No source, config, dependency or git state was changed.

1. Executive summary

70 / 100

This is a well-built codebase. The architecture has a clear structure: one SQLite file per user, request scoping through `AsyncLocalStorage`, zod schemas shared between server and client, and Hono RPC types going all the way to the phone. Lint and typecheck are clean, 185 tests pass, API line coverage is 93.6%, and no source file comes close to the 800-line ceiling.

The serious problems are at the edges. The offline write queue is deleted whenever any request returns 401, and because the 30-day token has no refresh path, that happens on a schedule. Session and token handling are weak: the JWT goes in image URLs and cannot be revoked. A few correctness and operations gaps remain: LIKE search, nightly jobs on the event loop, and no CI. None of these is a deep design flaw, and most can be fixed in under a day.

Severity	Count
Critical	1
High	1
Medium	15
Low	9
Total	26

Top 5 issues to fix first

- CQ-001** **Critical** Any 401 signs the user out and clears the offline write queue. With a fixed 30-day token, the next write after expiry is lost without warning.
- CQ-002** **High** If reading from SecureStore fails, the app stays on the splash screen forever. The `loadToken()` rejection is never handled.
- CQ-005 / CQ-006** **Medium** The 30-day JWT goes into receipt image URLs, which end up in Nginx logs and the image cache. It cannot be revoked or refreshed.
- CQ-008** **Medium** The assistant builds internal request paths from IDs and statuses chosen by the model. `x/../../settings` resolves to `/settings`.
- CQ-017** **Medium** Search escapes `%/_` with a backslash but has no `ESCAPE` clause. Searching "50%" returns nothing (verified).

Scorecard

Area	Score	Justification
Architecture	8	Clean module-per-domain API, a shared package used in both directions, typed RPC to the client, zero runtime import cycles. The assistant re-entering its own routes is clever but leaks path strings (CQ-008).
Readability & maintainability	7	Small files (largest source file is 509 lines), helpful comments, no TODO/FIXME. A few 260–440-line components and closures do too much (CQ-020).
Type safety	8	Strict mode plus <code>noUncheckedIndexedAccess</code> , <code>one any</code> , <code>no @ts-ignore</code> , <code>zod</code> at every server boundary. Biome allows <code>!</code> (44 uses), and some client JSON is cast without checks.
Error handling	5	Consistent error envelope on the server. On the client, a 401 wipes data, startup can hang, and there is no error boundary.
Security	6	Strong data isolation and Google token checks. Session handling is weak (no revocation, token in URLs), the rate limiter trusts a header, cleartext is allowed, and the cache sits unencrypted on the device.
Performance	6	Aggregates are done with Maps and indexed queries, and list endpoints are capped. However, hourly jobs block the event loop, DB handles are never closed, and AI loops keep running after the client disconnects.
Data layer	7	Money is stored as integer minor units, balances are derived, transactions and upserts are correct. There are no CHECK constraints or FKs on self-references, LIKE is broken, and backups stay on the same host.
Tooling & DX	6	One <code>bun run check</code> covers lint, typecheck and tests, and it is green. There is no CI, coverage numbers are misleading, and deploy config has drifted.
Testing	6	The API is well covered, including user isolation and the auth 401 path. The mobile data path (auth, HTTP, outbox) has no tests at all.
Dependencies	7	Lockfile is committed and versions are consistent (one React, Hono, TypeScript). There are 6 advisories, all in build tooling, and two Expo packages may be unused.

Overall score is a weighted judgement, not an average. Security, error handling and data integrity count double because this app holds personal finance records.

2. Scope & method

What was reviewed

- **apps/api** (91 source files, 8,125 lines): Hono app, middleware, Drizzle schema and migrations, user registry, jobs, AI client and assistant, every route module.
- **apps/mobile** (235 files, 17,325 lines): `src/lib` (auth, HTTP, query client, outbox, receipts), root layout, the largest feature screens, `app.json`, `eas.json`.
- **packages/shared** (16 files, 2,880 lines): schemas, money, dates.
- Config: `biome.json`, `tsconfig.base.json` and per-workspace tsconfigs, `bunfig.toml`, `.gitignore`, `deploy/nginx-tick-taka.conf`, `apps/api/ecosystem.config.cjs`, `.env.example` files.
- Docs used as the yardstick: `README.md`, `PRODUCT.md`, `docs/IMPLEMENTATION_PLAN.md`. Owner rules: an 800-line ceiling, no barrel index files, strict TypeScript, Conventional Commits.

Commands run

Command	Result
<code>bunx biome check .</code>	388 files, 0 diagnostics, exit 0
<code>bun run typecheck</code>	shared / api / mobile all exit 0
<code>bun run test</code>	api 100 pass (9 files), shared 71 pass, mobile 14 pass, 0 fail
<code>bun test --coverage per workspace</code>	api 93.60% lines / 86.29% funcs; shared 88.82% / 76.54%; mobile 71.63% / 81.73% (only 5 files are loaded)
<code>bun audit</code>	6 vulnerabilities (2 high, 4 moderate), exit 1
<code>rg pattern counts</code> (Appendix B)	<code>any</code> , <code>casts</code> , <code>!</code> , <code>console</code> , <code>catch blocks</code> , <code>raw SQL</code> , <code>list rendering</code>
TypeScript-AST script (function sizes) and import-graph Tarjan SCC (cycles)	Top functions in Appendix C; 0 runtime import cycles across 341 files
<code>bun -e probes</code>	Confirmed SQLite LIKE escaping (CQ-017) and URL <code>..</code> normalisation (CQ-008)
<code>git log --all --name-only</code> , <code>git grep</code> for key patterns	No <code>.env</code> , <code>DB</code> , <code>keystore</code> or <code>API key</code> ever committed

Not verified

- No device or emulator run. CQ-002 (startup hang) and CQ-020 render-cost claims are based on reading the code. They are marked Unverified.
- The production server's live configuration (actual `HOST`, `TLS`, `Nginx log format`, `firewall`) is unknown. Only files in the repo were read.
- No outdated-version check: `bun outdated` needs network access, and versions were judged from the lockfile only.
- CQ-008 was checked at the URL-normalisation level, not through a full prompt-injection run against a model.

3. Findings

Findings are grouped by category and sorted by severity. Effort: S < 1 h, M < 1 day, L > 1 day. Line numbers refer to commit 3b5438b.

3.1 Error handling & data integrity

CQ-001 · Any 401 deletes the offline write queue (and the token expires on a schedule)

Critical · Error handling / data integrity · Effort M

Where

apps/mobile/src/lib/http.ts:46-50, apps/mobile/src/lib/auth.ts:103-111,
apps/mobile/src/lib/user-data.ts:20-31, apps/api/src/modules/auth/routes.ts:11,43-49,
apps/mobile/src/lib/query-client.ts:79

What's wrong

Every response goes through a `ky afterResponse` hook. A 401 from any non-`/auth/` URL calls `signOut()`, and `signOut()` runs `clearUserData()`, which clears the TanStack mutation cache. That cache is the offline outbox. Tokens are issued for a fixed 30 days and the app never refreshes them. So the first write after expiry (a quick-add from the widget or a shortcut, or a write replayed after an offline spell) gets a 401, and the 401 deletes that write along with everything else in the queue. Separately, the persisted cache has `maxAge = 14` days, so writes that sat offline longer than that are dropped when the cache is restored.

Evidence

```
// http.ts:46-50
afterResponse: [{ request, response } => {
  if (response.status === 401 && !request.url.includes("/auth/")) auth.onUnauthorized();
}],
// auth.ts:111
connectAuth({ token: () => tokenStore.get(), onUnauthorized: () => void signOut() });
// user-data.ts:21-23
await queryClient.cancelQueries();
queryClient.getMutationCache().clear(); // <- queued offline writes gone
// auth/routes.ts:11
export const TOKEN_TTL_SECONDS = 30 * 24 * 60 * 60; // no refresh endpoint exists
```

Why it matters

Fast capture that works offline is the product's main promise ("Capture beats organise", offline queue in IMPLEMENTATION_PLAN Phase 7). Losing a logged expense without telling the user breaks trust in the safe-to-spend number.

Recommendation

Separate "session expired" from "sign out". On 401, pause the outbox (`onlineManager.setOnline(false)` or a paused flag) and send the user to re-authenticate *without* clearing mutations. Only `signOut()` started by the user should wipe data, and it should warn first if `getMutationCache().getAll().some(m => m.state.isPaused)`. Add a sliding refresh, for example re-issuing the token on `GET /me` when it has less than 7 days left. Set the outbox's persisted `maxAge` to at least the token lifetime.

CQ-002 · Startup hangs on the splash screen if SecureStore or profile parsing throws

High · Error handling · Effort S · **Unverified on device**

Where

apps/mobile/src/lib/auth.ts:28-35, apps/mobile/src/app/_layout.tsx:66-80

What's wrong

`ready` requires `token !== undefined`, and `tokenStore` starts as `undefined`. `loadToken()` is fired with `void`. If `SecureStore.getItemAsync` rejects (a known failure after Android Keystore invalidation or a device restore), or if `JSON.parse(profile)` throws, the store is never set. The layout then returns `null` forever with the splash screen still showing.

Evidence

```
// auth.ts:28-35
export async function loadToken(): Promise<void> {
  const [token, profile] = await Promise.all([ SecureStore.getItemAsync(TOKEN_KEY), ... ]);
  profileStore.set(profile ? (JSON.parse(profile) as Profile) : null);
  tokenStore.set(token ?? null);
}
// _layout.tsx
const ready = fontsLoaded && token !== undefined;
useEffect(() => { void loadToken(); ... }, []);
if (!ready) return null;
```

Why it matters

The app becomes unusable with no message, and the only fix is clearing app data, which also deletes the offline queue.

Recommendation

Wrap the body in `try/catch`. On failure, delete both keys and set `tokenStore.set(null)` so the user lands on login. Validate the profile with a small zod schema instead of the `as Profile` cast.

CQ-003 · No React error boundary anywhere in the app

Medium · Error handling · Effort S

Where

apps/mobile/src/app/ (all route files), especially `_layout.tsx`

What's wrong

`rg -n "ErrorBoundary" apps/mobile/src` returns 0 matches. expo-router supports `export function ErrorBoundary` per route, but none is defined. Any render-time exception, such as an unexpected `null` in cached data restored from an older build, crashes the whole tree.

Why it matters

Data is cached for 7–14 days and restored on start. If a shape mismatch reaches a render path, the app crashes again on every launch.

Recommendation

Export an `ErrorBoundary` from `_layout.tsx` (and from heavy screens such as Insights). Offer "Try again" (`retry()`) and "Reset cached data" (`persister.removeClient()`, keeping the outbox). Bump the persister `buster` whenever API response shapes change.

CQ-004 · Server logging is bare `console.*`, and the error mapper's branches are untested

Low · Error handling / observability · Effort S

Where

apps/api/src/middleware/error-handler.ts:13-28 (coverage 72%, lines 9, 17, 22-26 uncovered),
apps/api/src/jobs/scheduler.ts:27-29, apps/api/src/ai/usage.ts:89,

apps/api/src/modules/ai/routes.ts:114

What's wrong

The source has 5 `console.*` calls in total. Unknown errors are logged with no method, path, user ID or request ID. The `HTTPException` branch and the `SQLite FK/UNIQUE → 400/409` mapping have no tests.

Recommendation

Add a small request-ID middleware and log one JSON line per error, including `{reqId, userId, method, path, code}`. Add two tests that trigger an FK violation and a duplicate primary key through a route.

3.2 Security

CQ-005 · The 30-day bearer token travels in receipt image URLs

Medium · Security · Effort M

Where

apps/api/src/middleware/auth.ts:15-17, apps/mobile/src/lib/receipts.ts:53-56,
deploy/nginx-tick-taka.conf:10-18

What's wrong

Receipt images are loaded from `/uploads/<name>?token=<JWT>`. Nginx's default `combined` access log records the full request line. `expo-image` keys its disk cache by URL. The token is the full API credential, valid for 30 days (see CQ-006).

Evidence

```
// receipts.ts:54-56
export function receiptUrl(path: string): string {
  return `${apiUrl(`/uploads/${path}`)}?token=${encodeURIComponent(tokenStore.get() ?? "")}`;
}
```

Why it matters

Anyone who can read server logs, or a backup of them, can act as the user for up to a month.

Recommendation

Pass headers to `expo-image` instead (`source={{ uri, headers: authHeaders() }}`), which it supports. If a query parameter is still needed, issue a short-lived signed URL (an HMAC of `name+exp`, 5 minutes) that is scoped to the one file and cannot be used as an API token.

CQ-006 · Sessions cannot be revoked or refreshed

Medium · Security · Effort M

Where

apps/api/src/modules/auth/routes.ts:43-50, apps/api/src/middleware/auth.ts:19-28,
apps/mobile/src/lib/auth.ts:103-109

What's wrong

The HS256 JWT carries only `sub/iat/exp`, with no `jti`, token version, `aud` or `iss`. Sign-out only deletes the token on the phone, and the server has no record to invalidate. The only kill switch is rotating `JWT_SECRET`, which signs out every user.

Recommendation

Add `token_version` `INTEGER` to `users` (`users.db`). Put it in the JWT and compare it in `requireAuth` (one indexed lookup, which `deps.users.find` already does). Add `POST /auth/logout` to bump it. Pair this with the sliding refresh from CQ-001 and shorten the TTL to around 7 days.

CQ-007 · The API binds 0.0.0.0 by default, and the login limiter trusts X-Real-IP

Medium · Security · Effort S

Where

`apps/api/src/env.ts:5`, `apps/api/src/modules/auth/routes.ts:23-29`,
`apps/api/src/middleware/rate-limit.ts:5-27`

What's wrong

`HOST` defaults to `"0.0.0.0"`. Only the README and `.env.example` say `127.0.0.1`. If the port is reachable, clients can set `X-Real-IP` themselves and get a fresh limiter bucket per request. Requests without the header all share one `"local"` bucket, so 10 bad attempts lock everyone out. Keys are deleted only on a successful sign-in, so the `Map` grows by one entry per distinct IP forever. Authenticated and AI routes have no rate limiting at all; only the monthly cost cap applies.

Evidence

```
HOST: z.string().default("0.0.0.0"),           // env.ts:5
const ip = c.req.header("x-real-ip") ?? "local"; // auth/routes.ts:27
```

Recommendation

Default `HOST` to `127.0.0.1`. Trust `X-Real-IP` only when the socket peer is loopback (`Bun: server.requestIP(req)`), and fall back to the peer address otherwise. Prune expired keys inside `attempt()`, or sweep them every N calls. Add a per-user token bucket on `/ai/*`, for example 30 requests a minute.

CQ-008 · The assistant builds internal request paths from strings chosen by the model

Medium · Security (prompt injection) · Effort S

Where

`apps/api/src/modules/ai/assistant/tools.ts:244-251` (also the delete loop around 286-292 and the `act` paths at 328-382), `apps/api/src/modules/ai/assistant/entities.ts:24-25,31`,
`apps/api/src/app.ts:37`

What's wrong

`id` comes from the model's tool arguments (`String(args.id)`) and is placed straight into ``${def.path}/${id}``. `status` goes into the query string without encoding. `app.request()` builds a new `Request("http://localhost"+path)`, and URL parsing collapses dot segments. I verified that `new URL("http://localhost/tasks/x/../../settings").pathname === "/settings"`. Text the model reads, such as a transaction note, could therefore steer an "update task" into `PATCH /settings`, or another route, with the user's own authorization header.

Why it matters

The damage stays inside the user's own database, because per-user isolation holds. It still bypasses the entity allow-list that the tool layer is meant to enforce. The privacy page promises the assistant "can add and change records only through the same checks as the app itself."

Recommendation

Validate every ID with the shared `idSchema` (ULID regex) before building a path, and reject anything else as a `FieldError`. Build query strings with `URLSearchParams`, and check `status` against the entity's enum.

CQ-010 · All cached financial data and queued writes are stored unencrypted in AsyncStorage

Medium · Security / privacy · Effort M

Where

`apps/mobile/src/lib/query-client.ts:74-79`, `apps/mobile/src/app/_layout.tsx:88-91`

What's wrong

The token is stored correctly in `SecureStore` (`auth.ts:96-97`). But the whole `TanStack` cache (accounts, balances, transactions with notes, the assistant chat) and the paused-mutation outbox are written as plain JSON under `tt.query-cache`. The app lock (`features/security/app-lock.tsx`) only hides the UI.

Recommendation

Turn off Android auto-backup for the `AsyncStorage` DB (`android.allowBackup=false` via a config plugin) at a minimum. For stronger protection, encrypt the persisted blob with a key kept in `SecureStore` (AES-GCM through `expo-crypto`), or switch the persister to an encrypted store.

CQ-011 · The code has no account-deletion path, even though sign-up is open and the privacy policy promises deletion

Medium · Security / privacy compliance · Effort M

Where

`apps/api/src/modules/site/pages.ts:27,92-95`, `apps/api/src/db/user-registry.ts:59-64` ("Sign-up is open"), `apps/api/src/app.ts:38-66` (no delete route)

What's wrong

The policy says "we delete your account, records, receipt photos and backups within 30 days". No route, script or admin tool does this. An operator would have to find and delete `users/<id>.db`, its `-wal/-shm` files, `uploads/users/<id>`, `backups/users/<id>` and the `users` row by hand, while the process still holds the handle open (CQ-013).

Recommendation

Add `DELETE /me`. It should close and evict the cached handle, remove the DB files, uploads and backups, and delete the registry row. Link to it from Settings. Google Play also requires an in-app deletion path for apps that create accounts.

CQ-009 · Production builds allow cleartext HTTP

Low · Security · Effort S

Where

`apps/mobile/app.json:55` (`"usesCleartextTraffic": true` under `expo-build-properties`), `apps/mobile/src/lib/config.ts:2` (fallback `http://10.0.2.2:3000`)

What's wrong

The production and preview profiles point at HTTPS (`eas.json:12,16`), but the APK still allows HTTP to any host. If `EXPO_PUBLIC_API_URL` is ever missing from a build, it silently falls back to cleartext.

Recommendation

Enable cleartext only in the development profile (an `app.config.ts` that reads `EAS_BUILD_PROFILE`). Throw at startup if a release build's `API_URL` does not start with `https://`.

CQ-012 · `bun audit`: 6 advisories (2 high), all in build tooling

Low · Security / dependencies · Effort S

Where

`docs/audit/2026-10-06/_raw/audit.txt`

What's wrong

High: `braces` `<=3.0.3` (through `tailwindcss`, `expo`, `react-native`, `react-native-worklets`) and `node-forge` `<=1.4.0` (through `expo`). Moderate: `postcss-selector-parser`, `decode-uri-component` (`expo-router`), `esbuild` (`drizzle-kit`, `tailwindcss`), `uuid`. None reaches the API's runtime dependency tree. These are bundler, CLI and dev-server code, except `decode-uri-component` through `expo-router`, which may be bundled (only a DoS on malformed deep links).

Recommendation

Run `bun update` within the current ranges and re-audit. Add `bun audit` to CI (CQ-023) as a non-blocking report.

3.3 Performance

CQ-013 · DB handles are never closed, and nightly jobs run synchronously on the only event loop

Medium · Performance / scalability · Effort M

Where

`apps/api/src/db/user-registry.ts:87,148-157`, `apps/api/src/jobs/scheduler.ts:17-37`, `apps/api/src/jobs/backup.ts:27`, `apps/api/ecosystem.config.cjs:14`

What's wrong

`open` is a `Map` that only grows. Every hour, `runHourlyJobs` calls `deps.users.data(user)` for every user. That opens (and keeps open) every database, which means 3 file descriptors with WAL plus page cache each, and runs migrations and seeding on first open. At 03:00 local time each user's `VACUUM INTO` runs synchronously in the same loop that serves requests. Sign-up is open, so this cost grows with every account, and `pm2` restarts at 300 MB.

Evidence

```
for (const user of deps.users.list()) {
  const data = deps.users.data(user);           // opens + caches forever
  runAsUser({ user, data }, () => { ...
    if (hour === BACKUP_HOUR) safely("nightly-backup", () => runBackup(data.sqlite, ...));
```

Recommendation

Turn the handle cache into an LRU (say 50 entries) that calls `sqlite.close()` on eviction. Run backups with `await` and a yield between users (`await Bun.sleep(0)`), or in a `Worker`. Skip users whose `last_seen_at` is older than the newest backup.

CQ-014 · The AI assistant loop keeps spending after the client goes away

Medium · Performance / cost · Effort S

Where

apps/api/src/modules/ai/routes.ts:93-124, apps/api/src/modules/ai/assistant/agent.ts:13-14,165, apps/api/src/ai/openai-client.ts:20, apps/api/src/ai/usage.ts:71-81

What's wrong

The SSE handler never checks `stream.aborted` or registers `stream.onAbort`, and no `AbortSignal` is passed to OpenAI (rg "onAbort|aborted|AbortController" apps/api/src returns 0 matches). A turn can run 12 rounds × 45 s timeout × 1 retry after the phone has given up (client timeout is 90 s). The monthly cap is checked once before the turn starts, so concurrent turns can each overshoot it.

Recommendation

Create an `AbortController` per request, abort it in `stream.onAbort`, pass `signal` into every `openai.*` call, and check `signal.aborted` between rounds. Re-check the cap between rounds as well.

CQ-015 · Every mutation invalidates every query

Low · Performance · Effort M

Where

apps/mobile/src/lib/query-client.ts:23-27,41-48

What's wrong

`scheduleRefresh()` calls `queryClient.invalidateQueries()` with no filter, 250 ms after any mutation succeeds or fails. Each active screen's queries refetch, which means Today, budgets and insights aggregates are recomputed on the server for a single checkbox tick. The comment ("one user, small data") makes this a deliberate trade-off, but its cost grows with history.

Recommendation

Keep the debounce, but map outbox paths to key prefixes (`/transactions` → [`money`, `today`, `insights`], `/tasks` → [`tasks`, `today`, `plan`]). Keep the global invalidate as a fallback for unknown paths.

CQ-016 · `/sync/changes` is unused, and it and `/export` return unbounded results

Low · Performance / dead code · Effort S

Where

apps/api/src/modules/sync/routes.ts:11-43, apps/api/src/db/schema/*.ts (only `tasks` and `transactions` index `updated_at`)

What's wrong

The mobile app never calls `/sync/changes` (rg "sync|changes" apps/mobile/src/lib finds nothing relevant). The endpoint scans 20 tables with `updated_at > ?`, and 18 of those tables have no index on that column. With `since=0` it returns everything in one JSON body. `/export` also loads every row of every table into memory.

Recommendation

Delete `syncRoutes` until there is a client for it, or add per-table `limit` and a cursor. Stream `/export` table by table.

3.4 Data layer

CQ-017 · LIKE search escaping is broken: "50%" and "a_b" never match

Medium · Data layer / correctness · Effort S

Where

apps/api/src/modules/transactions/service.ts:75-76,
apps/api/src/modules/tasks/service.ts:155-157

What's wrong

Both services prefix `%` and `_` with a backslash, but SQLite treats a backslash as an escape character only when the query has an `ESCAPE '\\'` clause, and Drizzle's `like()` does not add one. The pattern then looks for a literal backslash. I verified this with `bun:sqlite: '50% off' LIKE '%50\\%'` returns 0 rows, and with `ESCAPE char(92)` it returns 1. The same helper logic is copied in both services.

Evidence

```
filters.push(like(transactions.note, `${query.q.replace(/[_]/g, (m) => `\\${m}`)}%`));
```

Recommendation

Add a shared helper in `apps/api/src/lib/: sql`${col} LIKE ${pattern} ESCAPE '\\'`, and also escape the backslash itself (`/[\\%_]/g`). Add a test that searches "50%".

CQ-018 · The database has no CHECK constraints, and self-references have no foreign keys

Medium · Data layer · Effort M

Where

apps/api/drizzle/0000_init.sql:151-170 (type text NOT NULL, amount_minor integer NOT NULL), apps/api/src/db/schema/time.ts:34,60 (tasks.parent_id, tasks.goal_id),
apps/api/src/db/schema/money.ts:20 (categories.parent_id)

What's wrong

`grep -c CHECK drizzle/*.sql` returns 0. Drizzle's `text(..., { enum })` is enforced in TypeScript only. Enum values, positive amounts for non-adjustments, `fee_minor >= 0`, month/date formats and `ended_at >= started_at` all depend on zod alone. Any other write path (the migration in 0002, a future script, a hand fix in `sqlite3`) can store values the aggregates do not expect. `tasks.goal_id` was added in 0001 without a reference.

Recommendation

Add `check()` constraints in the Drizzle schema for enums and signs, and `.references()` for `parentId` and `goalId`. SQLite cannot add constraints in place, so generate a table-rebuild migration and test it against a copy of a real backup.

CQ-019 · Backups stay on the same disk as the live data

Medium · Data layer / operations · Effort M

Where

apps/api/src/jobs/backup.ts:8-11 ("Backups stay on the server"), apps/api/src/env.ts:72-76,
README "Backups"

What's wrong

By default `BACKUPS_DIR` sits next to `DB_PATH` on the same VPS volume. If the disk fails, the provider deletes the VPS, or someone runs `rm -rf ~/tick-taka-data`, both the data and all 14 backups are gone. The only off-box copy is the user's manual JSON export.

Recommendation

After `VACUUM INTO`, push the file to object storage (Backblaze B2 or S3 with `rc1one` from cron, or the S3 client in Bun). Encrypt it with `age` first, and document a restore drill.

3.5 Architecture, readability & type safety

CQ-020 · A handful of 260–440-line components and closures carry too many responsibilities

Medium · Maintainability · Effort L

Where

`features/tasks/task-sheet.tsx:67-509` (TaskSheet, 443 lines), `features/money/transaction-sheet.tsx:65-437` (373), `api/modules/tasks/service.ts:39-371` (taskService, 333), `api/modules/ai/assistant/tools.ts:178-487` (createToolRunner, 310), `features/quick-add/use-quick-add.ts:31-297` (267). Full list in Appendix C.

What's wrong

None of these breaks the 800-line ceiling (the largest source file is 509 lines). However, each function mixes several concerns. For example, TaskSheet combines form state, project and area queries, recurrence UI, subtasks, reminders and delete/restore in one render function, and `createToolRunner` holds `find`, `create`, `update`, `delete`, a 10-case `act` switch and the undo log. These are also the least-covered API areas: `tools.ts` 73% lines, with 343-454 uncovered.

Recommendation

Split along seams that already exist. Move TaskSheet's recurrence and reminder sections to `features/tasks/_components/`-style siblings, and move the subtask list to its own component. Move each `act` case in `tools.ts` into a table of handlers (`Record<Action, (args) => Promise<Result>>`) in a sibling module. These are moves, not rewrites. Keep the JSX byte-identical.

CQ-021 · The time-zone and week-start fallbacks are repeated at 24 call sites

Low · Maintainability · Effort S

Where

`packages/shared/src/dates.ts:6` defines `DEFAULT_TIME_ZONE`. Even so, `settings?.timeZone ?? "Asia/Dhaka"` appears 18 times in `apps/mobile/src`, and `weekStartsOn ?? 6` appears 6 times (e.g. `features/plan/logbook-list.tsx:22,27`, `lib/query-client.ts:67`).

Recommendation

Add `useUserTime()` in `apps/mobile/src/lib/` that returns `{ timeZone, weekStartsOn, today }` from `useSettings()`, using the shared defaults. This mirrors the server's `userTime(deps)`.

CQ-022 · Non-null assertions are allowed, and client JSON is cast without checks

Low · Type safety · Effort M

Where

`biome.json:21-24` (`noNonNullAssertion: "off"`); 44 ! sites in source, e.g. `api/modules/ai/planning.ts:53,69` (`t.doAt!`), `api/modules/tasks/service.ts:305,355`, `api/modules/today/service.ts:119` (`debt.remindAt!`), `mobile/features/plan/day-timeline.tsx:177`. Unchecked casts: `mobile/src/lib/api.ts:49` (`unwrap`), `api.ts:66` (`send<T>`), `auth.ts:33,86`.

What's wrong

Most `!s` on domain fields rely on a filter defined somewhere else, for example "only tasks with `doAt` were selected". If that filter changes, the code yields `NaN` times instead of a compile error. On the client, typed RPC gives compile-time shapes, but persisted cache data from older builds is never re-validated.

Recommendation

Turn the rule back on as `warn`, and narrow with type guards (`.filter((t): t is Task & {doAt: number} => t.doAt !== null)`). Validate the few hand-cast client payloads (profile, sign-in body) with `zod`.

3.6 Tooling, testing & dependencies

CQ-023 · No CI: the green `bun run check` is enforced by nothing

Medium · Tooling & DX · Effort S

Where

Repo root (no `.github/`, no other CI config, no git hooks); `package.json:12` defines `"check"`.

What's wrong

IMPLEMENTATION_PLAN says "Every phase ends with tests passing", but this rests on discipline alone. The README deploy flow is `git pull && bun install && pm2 restart`, with no gate and no `--frozen-lockfile`.

Recommendation

Add `.github/workflows/check.yml` with `oven-sh/setup-bun`, `bun install --frozen-lockfile`, `bun run check` and a non-blocking `bun audit`. Use `bun install --frozen-lockfile` in the deploy steps.

CQ-024 · The mobile data path has no tests, and coverage numbers mislead

Medium · Testing · Effort M

Where

`apps/mobile/test/` (5 files, 240 lines: `format`, `optimistic-spend`, `plan-notifications`, `server-clock`, `widget-snapshot`); `_raw/coverage-*.txt`

What's wrong

`lib/http.ts`, `lib/auth.ts`, `lib/query-client.ts`, `lib/outbox.ts` and `lib/user-data.ts` are untested, and they are exactly where CQ-001 and CQ-002 live. Mobile "71.6%" covers only the 5 files the tests import. `packages/shared/src/dates.ts` reports 0% lines with 79–90% functions, and `money.ts` reports about 1% lines with 100% functions. That combination is a Bun coverage artifact, not real coverage, so the numbers cannot be used as a gate.

Recommendation

Test the outbox and auth with a stubbed `fetch`. Given queued writes and a 401 response, the mutation cache should still hold them (this is the regression test for CQ-001). Given `SecureStore` rejects, `tokenStore` should become `null` (CQ-002). Report function coverage, or cross-check with `-coverage-reporter=lcov`, before relying on the line numbers.

CQ-025 · Deploy configuration has drifted between files

Low · Tooling / operations · Effort S

Where

deploy/nginx-tick-taka.conf:5,11 (tick.mehedismathacademy.com → 127.0.0.1:3003),
apps/mobile/eas.json:12,16 (https://tt-api.bipulhf.dev), apps/api/.env.example (PORT=3000),
README:266

What's wrong

The APK targets a host that no Nginx file in the repo serves. The example port does not match the proxy port. The Nginx file listens on port 80 only until certbot rewrites it, and it has no `proxy_read_timeout` or `proxy_buffering off` for the SSE assistant. The server sends `x-accel-buffering: no`, which covers buffering, but the timeout still relies on the 15 s keepalive.

Recommendation

Pick one hostname and port and put it in all three files. Commit the post-certbot TLS server block, and add `proxy_read_timeout 120s;` to match Bun's `idleTimeout: 120`.

CQ-026 · Dependency hygiene: possibly unused Expo packages, two zod majors, caret ranges on server runtime

Low · Dependencies · Effort S · **Partly unverified**

Where

apps/mobile/package.json, apps/api/package.json, bun.lock

What's wrong

Nothing in `src` or the config files imports `expo-navigation-bar` or `expo-system-ui`. Others with no direct import (`expo-constants`, `expo-linking`, `expo-font`, `react-native-screens`, `react-native-worklets`, `expo-dev-client`) are required peers or plugins, so they are fine. The lockfile holds both `zod@3.25.76` (transitive) and `zod@4.6.5`. Server runtime dependencies use caret ranges (`hono ^4.13.13`, `openai ^7.27.0`, `drizzle-orm ^0.45.3`). That is safe with a frozen lockfile, but deploys do not freeze it (CQ-023). There is no `packageManager` field to pin the Bun version.

Recommendation

Run `npx expo install --check` and remove the two packages if they are not needed. Add `"packageManager": "bun@1.3.11"` at the root. Freeze the lockfile on deploy.

4. Strengths: keep these

- **Isolation by design.** Each user has their own SQLite file (`user-registry.ts:59-64`), and `AsyncLocalStorage` scoping makes `deps.db` always point to the current user's database (`lib/deps.ts:32-49`, `lib/user-scope.ts`). No query can reach another user's rows, and `users.test.ts` covers this.
- **Thorough Google ID-token verification.** RS256 against JWKS with cache-control TTL, retry on key rotation, `iss/aud` checks, `email_verified` required (`lib/google.ts`).
- **Validation at every server boundary.** Shared zod schemas are used through one `validate()` wrapper with a consistent `{error:{code,message,details}}` envelope (`lib/validate.ts`, `lib/errors.ts`). The env is validated at boot (`env.ts`, `JWT_SECRET` at least 32 characters).
- **End-to-end types.** The mobile app uses `hc<AppType>` over `ky` (`mobile/src/lib/api.ts:19`), so route and response types come straight from the server.
- **Money done right.** Amounts are integer minor units everywhere, conversion happens only at the edges with explicit rounding (`shared/src/money.ts`), and balances are derived from transactions rather than stored (`lib/money-queries.ts`).
- **Offline-safe writes on the server.** Creates are idempotent on client ULIDs, last write wins against the server clock (`x-server-time`), multi-row writes run in transactions, and upserts correctly revive soft-deleted rows under unique indexes (`budgets/service.ts:216-248`, `category-rules/service.ts:17-30`).
- **AI guardrails.** A per-feature off switch, a monthly cost cap, a fake provider in tests, and assistant writes that go through the app's own validated routes with undo records.
- **Hygiene.** 0 lint diagnostics, 0 type errors, 185 passing tests, API line coverage 93.6%. One `any` (and that one is commented), no `@ts-ignore`, no TODO/FIXME, no runtime import cycles, no barrel files, largest source file 509 lines. No secrets in git history. Public HTML pages escape their inputs. Upload file names are regex-checked (no path traversal).
- **Secure token at rest.** The JWT is kept in `expo-secure-store`, and sign-out wipes cache, queue, notifications and widget data.

5. Action plan

Refactoring roadmap

When	Items
Now (this week)	CQ-001 keep the outbox on 401 and add a sliding refresh · CQ-002 try/catch in <code>loadToken</code> · CQ-017 add <code>ESCAPE</code> to <code>LIKE</code> · CQ-008 validate assistant IDs · CQ-007 default HOST 127.0.0.1 and trusted-proxy IP · CQ-023 CI workflow
Next (this month)	CQ-005 header-based image loading · CQ-006 token version and logout · CQ-003 error boundary · CQ-014 abort the AI loop · CQ-013 LRU handles and non-blocking backups · CQ-019 off-site backups · CQ-011 <code>DELETE /me</code> · CQ-024 mobile data-path tests
Later	CQ-018 CHECK/FK rebuild migration · CQ-010 encrypted persisted cache · CQ-020 split large components · CQ-015 scoped invalidation · CQ-016 remove <code>/sync</code> , <code>stream /export</code> · CQ-021 <code>useUserTime()</code> · CQ-022 <code>!</code> → type guards · CQ-009 dev-only cleartext · CQ-025 deploy config alignment · CQ-012 / CQ-026 dependency tidy-up

Prioritised table

Order	ID	Title	Severity	Effort
1	CQ-001	401 deletes offline write queue; no token refresh	Critical	M
2	CQ-002	Splash hang if SecureStore fails	High	S
3	CQ-017	LIKE escaping broken	Medium	S
4	CQ-008	Assistant path built from model strings	Medium	S
5	CQ-007	0.0.0.0 default and spoofable limiter key	Medium	S
6	CQ-023	No CI	Medium	S
7	CQ-003	No error boundary	Medium	S
8	CQ-005	Token in image URLs	Medium	M
9	CQ-006	No revocation or refresh	Medium	M
10	CQ-014	AI loop not aborted	Medium	S
11	CQ-013	DB handles and blocking backups	Medium	M
12	CQ-019	Backups on same disk	Medium	M
13	CQ-024	Mobile data path untested	Medium	M
14	CQ-011	No account deletion	Medium	M
15	CQ-010	Unencrypted persisted cache	Medium	M
16	CQ-018	No CHECK / missing FKs	Medium	M
17	CQ-020	Oversized components and closures	Medium	L
18	CQ-009	Cleartext allowed in release	Low	S
19	CQ-004	Unstructured logging	Low	S
20	CQ-012	6 tooling advisories	Low	S
21	CQ-025	Deploy config drift	Low	S

Order	ID	Title	Severity	Effort
22	CQ-015	Global invalidation	Low	M
23	CQ-016	Unused or unbounded sync/export	Low	S
24	CQ-021	Repeated TZ fallback	Low	S
25	CQ-022	! and unchecked casts	Low	M
26	CQ-026	Dependency hygiene	Low	S

6. Appendix

A. Raw command output (trimmed)

```
$ bunx biome check .
Checked 388 files in 367ms. No fixes applied.          exit 0

$ bun run typecheck
@tick-taka/shared typecheck: Exited with code 0
@tick-taka/api typecheck: Exited with code 0
@tick-taka/mobile typecheck: Exited with code 0

$ bun run test
@tick-taka/shared test: 71 pass, 0 fail (10 files)
@tick-taka/mobile test: 14 pass, 0 fail (5 files)
@tick-taka/api test: 100 pass, 0 fail (9 files) [2.69s]

$ bun test --coverage (All files: % Funcs | % Lines)
api      86.29 | 93.60 lowest: ai/ask.ts 62.68, middleware/error-handler.ts 72.00,
ai/assistant/tools.ts 73.46, categories/routes.ts 79.25
shared 76.54 | 88.82 dates.ts 79.31 | 0.00 (artifact), tiki.ts 68.52
mobile 81.73 | 71.63 only 5 files loaded

$ bun audit
braces <=3.0.3      high      via tailwindcss, expo, react-native, react-native-worklets
node-forge <=1.4.0  high      via expo
postcss-selector-parser moderate via tailwindcss
decode-uri-component moderate via expo-router
esbuild <=0.24.2    moderate via drizzle-kit (api), tailwindcss
uuid <11.1.1        moderate via expo, expo-sharing, expo-splash-screen
6 vulnerabilities (2 high, 4 moderate)                exit 1
```

B. Code health counts (source only: apps/api/src, apps/mobile/src, packages/shared/src)

Pattern	Count	Notes / locations
any	1	api/src/lib/crud.ts:45 (biome-ignore with justification). Tests: 0.
@ts-ignore / @ts-expect-error	0	
biome-ignore	4	crud.ts:44; chat-composer.tsx:70 (exhaustive deps); message-bubble.tsx:23,64 (index keys)
as unknown as	1	mobile/src/lib/receipts.ts:43 (RN FormData file)
as X casts (excluding as const and import aliases)	~187	Top: ai/assistant/tools.ts 16, lib/resource-routes.ts 9, lib/crud.ts 9, shared/schemas/time.ts 7, today/service.ts 7. as const: 71.
Non-null !	44	Biome rule disabled. Top: shared/quick-add.ts 6, tasks/service.ts 3, ai/planning.ts 3.
TODO / FIXME / HACK	0	
console.*	5	All server side: usage.ts:89, scheduler.ts:27,29, error-handler.ts:26, ai/routes.ts:114
Empty catch {}	2	ai/assistant/agent.ts:78,82. Benign: these build status labels from possibly malformed JSON.

Pattern	Count	Notes / locations
<code>.catch(() => ...)</code>	20	Mostly <code>.catch(() => {})</code> on best-effort calls (Google signOut, notifications)
Raw <code>sql`</code> fragments	3 (+ aggregates)	All parameterised through Drizzle; no string concatenation of user input. <code>backup.ts:27</code> interpolates a path and escapes <code>'</code> .
Raw <code>bun:sqlite</code> queries	registry only	user-registry.ts uses prepared statements with <code>?</code> placeholders
CORS middleware	none	Correct for a native-only client. Browsers cannot read API responses cross-origin.
Auth coverage	all	Unauthenticated: <code>/health</code> , site pages (<code>/</code> , <code>/privacy</code> , <code>/terms</code>), <code>POST /auth/google</code> . Every other route is under <code>requireAuth</code> (<code>app.ts:38-39</code>).
Lists: virtualised vs map	1 / 35	One <code>SectionList</code> (<code>transaction-list.tsx:47</code>). 35 screens use <code>Screen</code> (a <code>ScrollView</code>) with <code>.map</code> . Server lists are capped (tasks ≤ 500 , transactions ≤ 200 with cursor), and most screens are week- or month-bounded.
Runtime import cycles	0	Tarjan SCC over 341 files (type-only imports excluded). <code>http.ts</code> avoids an auth cycle on purpose through <code>connectAuth</code> .
Files over 800 lines	0	Largest source file is <code>task-sheet.tsx</code> at 509 lines. Largest test file is <code>money.test.ts</code> at 546.
Barrel <code>index</code> files	0	<code>index.ts(x)</code> files are entry points or routes only
Secrets in git	0	Only <code>.env.example</code> files are tracked. History has no <code>.env</code> , <code>.db</code> , <code>.apk</code> or keystore files. No <code>sk-</code> , <code>AIza</code> or PEM patterns.

C. Top functions by size (TypeScript AST)

Lines	Function	Location
443	TaskSheet	<code>apps/mobile/src/features/tasks/task-sheet.tsx:67-509</code>
373	TransactionSheet	<code>apps/mobile/src/features/money/transaction-sheet.tsx:65-437</code>
333	taskService	<code>apps/api/src/modules/tasks/service.ts:39-371</code>
310	createToolRunner	<code>apps/api/src/modules/ai/assistant/tools.ts:178-487</code>
267	useQuickAdd	<code>apps/mobile/src/features/quick-add/use-quick-add.ts:31-297</code>
260	InsightsScreen	<code>apps/mobile/src/features/review/insights-screen.tsx:43-302</code>
238	RecurringForm	<code>apps/mobile/src/features/money/recurring-sheet.tsx:46-283</code>
205	PlanHome	<code>apps/mobile/src/features/plan/plan-home.tsx:23-227</code>
198	WeeklyReview	<code>apps/mobile/src/features/review/weekly-review.tsx:26-223</code>
196	BudgetsScreen	<code>apps/mobile/src/features/money/budgets-screen.tsx:30-225</code>

Largest source files

`task-sheet.tsx` 509 · `ai/assistant/tools.ts` 487 · `shared/quick-add.ts` 475 · `shared/recurrence.ts` 462 · `transaction-sheet.tsx` 437 · `tasks/service.ts` 371 · `shared/schemas/money.ts` 310 · `insights-screen.tsx` 302 · `use-quick-add.ts` 297 · `safe-to-spend-widget.tsx` 292

D. Requirement checklist (engineering commitments from the docs)

Commitment (source)	Status	Evidence
TypeScript strict in every workspace (PLAN Phase 0, owner rules)	Met	tsconfig.base.json (<code>strict</code> , <code>noUncheckedIndexedAccess</code>); mobile tsconfig repeats both flags
800-line ceiling per file, no barrels (owner rules)	Met	Appendix B
Money as integers (PLAN, shared/money.ts)	Met	All <code>*_minor</code> integer columns; zod <code>.int()</code>
Per-user data isolation (README)	Met	user-registry.ts, user-scope.ts, users.test.ts
Offline queue that never loses writes (PLAN Phase 7, PRODUCT "Capture beats organise")	Partial	CQ-001
Login rate limit (PLAN Phase 2)	Partial	Exists and is tested (foundation.test.ts:68). Depends on proxy setup (CQ-007).
Nightly backup keeping 14 and a restore check (PLAN Phase 5, README)	Partial	backup.ts rotation is tested. Backups are on the same host (CQ-019) and block the loop (CQ-013).
AI cap and off switch, tested with a fake client (PLAN Phase 6)	Met	usage.ts:71-81, test/fake-ai.ts. Cap overshoot is possible (CQ-014).
Every phase ends with tests passing (PLAN)	Met locally, not enforced	CQ-023
Account and data deletion (site privacy page)	Missing in code	CQ-011

E. File inventory

Workspace	Source files	Source lines	Test files	Test lines
apps/api	91	8,125	12	2,564
apps/mobile	235	17,325	5	240
packages/shared	16	2,880	10	617
Total	342	28,330	27	3,421

API modules: accounts, ai (+assistant), areas, auth, budgets, categories, category-rules, debts, events, gamification, goals, habits, insights, projects, recurring, reviews, routines, settings, shopping, site, sync, tasks, time-entries, today, transactions, uploads. Migrations: 0000_init, 0001_task_goal_link, 0002_reprice_ai_usage.